

Lab Instruction and Submission Template: MITRE ATT&CK for Cyber Threat Intelligence (CTI)

Name: Abdulaziz

ID: 14510630

Date: 03/03/2025

Overview

This lab is designed to practice and deepen your understanding of the MITRE ATT&CK for Cyber Threat Intelligence (CTI). By working through practical exercises based on the framework, you will enhance your skills in identifying, understanding, and mitigating cyber threats.

Reference Material

- MITRE ATT&CK CTI Training: [Learn More about ATT&CK Training](#)
- Sample Answers Reference: [MITRE ATT&CK v6](#)
- Latest ATT&CK Version for Tasks: [MITRE ATT&CK v18](#)
- Latest ATT&CK Version: [Version history](#)

Tasks

Complete the following tasks using the ATT&CK version (v18.1), providing a rationale for each answer.

Exercise 1: Report Analysis

Analyze and annotate techniques in exercise 1 using the [MITRE ATT&CK® Navigator](#):

• Cybereason Cobalt Kitty

Document 21 entries of Tactics, Techniques, and rationales.

Index	Tactic	Technique	Reason
-------	--------	-----------	--------

1	Initial Access	T1566.002 Spearphishing Link	Spear phishing with link to a fake flash installer
2	Initial Access	T1566.001 Spearphishing Attachment	Word documents with malicious macros attached to the email
3	Defense Evasion	T1059.005 Command and Scripting Interpreter: Visual Basic	Malicious Word macros used VBScript to download payloads.
4	Execution	T1204.001 User Execution: Malicious Link	User was tricked into clicking the link that downloaded the fake installer.
5	Execution	T1059.003 Command and Scripting Interpreter: Windows Command Shell	The fake installer used cmd.exe to launch the next infection stages.
6	Persistence	T1053.005 Scheduled Task/job: Scheduled Task	Two scheduled tasks were created to ensure malicious code ran repeatedly
7	Defense Evasion	T1218.005 Signed Binary Proxy Execution: Mshta	Scheduled tasks used mshta.exe to execute malicious scripts from the C2.
8	Command and Control	T1105 Ingress Tool Transfer	Malicious scripts downloaded additional payloads like "microsoft.jpg" from the attacker's server.
9	Execution	T1059.001 Command and	Obfuscated PowerShell was

		Scripting Interpreter: PowerShell	used to download and execute final beacons.
10	Defense Evasion	T1027 Obfuscated Files or Information	Payloads were heavily obfuscated and camouflaged as .jpg files to avoid detection.
11	Persistence	T1547.001 Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	Registry "Run" keys were modified to launch scripts upon system startup.
12	Defense Evasion	T1096 NTFS File Attributes	Attackers used Alternate Data Streams to hide malicious code inside "hidden" text files.
13	Persistence	T1569.002 System Services: Service Execution	Malicious PowerShell scripts were configured to run as Windows services.
14	Persistence	T1543.003 Create or Modify System Process: Windows Service	Attackers created or modified services to maintain a constant foothold.
15	Persistence	T1137 Office Application Startup	A malicious Outlook macro was used to communicate with C2 servers on startup.
16	Defense Evasion	T1112 Modify Registry	A specific registry value was edited to ensure the malicious Outlook

			macro remained active.
17	Command and Control	T1071.001 Application Layer Protocol: Web Protocols	The attackers utilized standard HTTP protocols for their fileless infrastructure to communicate with C2 servers and blend in with normal traffic.
18	Command and Control	T1105 Ingress Tool Transfer	A PowerShell downloader one-liner was used to fetch and execute additional malicious payloads directly from the attacker's server.
19	Execution	T1218.010 Signed Binary Proxy Execution: Regsvr32	The attackers used regsvr32.exe to download and execute malicious COM scriptlets (.sct files) from a remote URL to bypass security controls.
20	Defense Evasion	T1036.005 Masquerading: Match Legitimate Name or Location	A customized NetCat binary was renamed to "kb-10233.exe" to masquerade as a legitimate Windows update and minimize suspicion during its use.
21	Discovery	T1046 Network Service Scanning	The attackers scanned internal

		network ranges to identify open ports, active services, and operating system versions to find further targets for lateral movement.
--	--	---

Include a screenshot of the annotated ATT&CK Navigator. You can use the “Export” function as follows and convert SVG to pdf then insert here.

about		domain		platforms	
Cobalt Kitty		Enterprise ATT&CK v18		Windows, Linux, macOS, Network Devices, ESXi, PRE, Containers, IaaS, Office Suite, SaaS, Identity Provider	
Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation
Defensive Evasion	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection
Command and Control	Command and Control	Command and Control	Command and Control	Command and Control	Command and Control
Impact	Impact	Impact	Impact	Impact	Impact
...	...	...	...	...	...

- APT39 Document 18 entries of Tactics, Techniques, and rationales.

Index	Tactic	Technique	Reason
1	Initial Access	T1566.001 Spearphishing Attachment	They sent emails with harmful files attached to trick people into opening them.
2	Initial Access	T1566.002 Spearphishing Link	They put links in emails that lead to malware when clicked.
3	Execution	T1204.002 User Execution: Malicious File	The attack starts running when a user opens the bad attachment.
4	Execution	T1204.001 User Execution: Malicious Link	The malware is triggered when a user clicks on the link in the email.
5	Persistence	T1505.003 Server Software Component: Web Shell	They put special scripts (web shells) on servers so they can always get back in.
6	Initial Access	T1078 Valid Accounts	They used stolen usernames and passwords to log into real company accounts.
7	Credential Access	T1003.001 OS Credential Dumping: LSASS Memory	They used tools to pull passwords directly out of the computer's active memory.
8	Execution	T1059 Command and Scripting Interpreter	They used coding scripts to tell the computer what to do.
9	Discovery	T1046 Network Service Scanning	They used a tool to look for "open doors" and other computers on the network.
10	Lateral Movement	T1021.001 Remote Services: Remote Desktop Protocol	They used the computer's own remote desktop

			feature to hop from one machine to another.
11	Lateral Movement	T1021.004 Remote Services: SSH	They used a secure login method (SSH) to move around inside the network.
12	Command and Control	T1090.002 Proxy: External Proxy	They set up a secret tunnel to send and receive commands without being noticed.
13	Exfiltration	T1560.001 Archive Collected Data: Archive via Utility	They packed the stolen data into ZIP-like files (WinRAR) to make it easier to steal.
14	Persistence	T1547.009 Boot or Logon Autostart Execution: Shortcut Modification	They changed regular icons (shortcuts) so the malware starts every time the PC is turned on.
15	Persistence	T1053.005 Scheduled Task/Job: Scheduled Task	They told the computer to run their bad code automatically at certain times.
16	Persistence	T1547.001 Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	They hid commands in the Windows "startup" settings to make sure their tools stay running.
17	Discovery	T1018 Remote System Discovery	They looked through the network to see which other computers were available to attack.
18	Defense Evasion	T1027.002 Obfuscated Files or Information: Software Packing	They scrambled or hid their tools so antivirus software wouldn't find them.

Include a screenshot of the annotated ATT&CK Navigator.

[illegible]

Exercise 2: Ticket Analysis

Provide detailed analysis for the following tickets:

- **ticket-473822**

Document entries of Tactics, Techniques, and rationales.

Index	Tactic	Technique	Reason
1	Discovery	T1016 System Network Configuration Discovery	Used ipconfig /all to see the computer's network setup and settings.
2	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to run the ipconfig command.

3	Discovery	T1016 System Network Configuration Discovery	Used arp -a to find hardware addresses on the local network.
4	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to execute the arp tool.
5	Discovery	T1033 System Owner/User Discovery	Used the echo command to reveal the current user and domain names.
6	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to run the echo command.
7	Discovery	T1057 Process Discovery	Used tasklist /v to list all programs currently running on the system.
8	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to execute the tasklist command.
9	Discovery	T1007 System Service Discovery	Used sc query to see a list of all active system services.
10	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to run the sc service query tool.
11	Discovery	T1082 System Information Discovery	Used systeminfo to get details about the OS and hardware.
12	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to execute the systeminfo tool.
13	Discovery	T1069.002 Permission Groups Discovery: Domain Groups	Used net group to find members of the "Domain Admins" group.
14	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to run the net group command.

15	Discovery	T1087.002 Account Discovery: Domain Account	Used net user to list all account names within the domain.
16	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to execute the net user command.
17	Discovery	T1018 Remote System Discovery	Used net group to identify the domain controller servers on the network.
18	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to identify the remote domain controllers.
19	Discovery	T1016 System Network Configuration Discovery	Used netsh to check the status and rules of the system's firewall.
20	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to execute the netsh command.
21	Discovery	T1049 System Network Connections Discovery	Used netstat -ano to see all active network connections and ports.
22	Execution	T1059 Command and Scripting Interpreter	Used the cmd.exe shell to run the netstat tool.

Include a screenshot of the annotated ATT&CK Navigator.

			command to move files from the server to the victim.
5	Execution	T1059 Command and Scripting Interpreter	Used the SHELL command to run instructions through cmd.exe.
6	Execution	T1059.001 Command and Scripting Interpreter: PowerShell	Used the PSHELL command to run scripts in powershell.exe.
7	Execution	T1106 Native API	Used the "CreateProcess" function to start programs directly.
8	Defense Evasion	T1036 Masquerading	Renamed the file to "winspool.exe" and moved it to System32 to look legitimate.
9	Persistence	T1547.001 Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	Added a registry key to make sure the program starts every time the user logs in.

Include a screenshot of the annotated ATT&CK Navigator.

Shells" to maintain a back door into web servers and use common file-shrinking tools (like WinRAR) to pack up the data they want to steal so it's easier to send out.

Exercise 4: Making Defensive Recommendations

Based on the techniques identified from the previous exercises, make defensive recommendations for your organization (assume you are running one).

Techniques identified from the previous exercise:

APT39

1. Initial Access – Phishing: Spearphishing Attachment (T1566.001)
2. Initial Access – Phishing: Spearphishing Link (T1566.002)
3. Initial Access – Valid Accounts (T1078)
4. Execution – Command and Scripting Interpreter (T1059)
5. Execution – Malicious File: User Execution (T1204.002)
6. Execution – Malicious Link: User Execution (T1204.001)
7. Persistence – Scheduled Task/Job: Scheduled Task (T1053.005)
8. Persistence – Boot or Logon Autostart Execution: Shortcut Modification (T1547.009)
9. Persistence – Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder (T1547.001)
10. Persistence – Server Software Component: Web Shell (T1505.003)
11. Defense Evasion – Obfuscated Files or Information: Software Packing (T1027.002)
12. Credential Access – OS Credential Dumping: LSASS Memory (T1003.001)
13. Discovery – Network Service Scanning (T1046)
14. Discovery – System Network Configuration Discovery (T1016)
15. Lateral Movement – Remote Services: Remote Desktop Protocol (T1021.001)
16. Lateral Movement – Remote Services: SSH (T1021/004)
17. Command and Control – Proxy: External Proxy (T1090.002)
18. Exfiltration – Archive Collected Data: Archive via Utility (T1560.001)

OceanLotus

1. Initial Access – Phishing: Spearphishing Attachment (T1566.001)
2. Initial Access – Phishing: Spearphishing Link (T1566.002)
3. Execution – Command and Scripting Interpreter: Visual Basic (T1059.005)
4. Execution/Defense Evasion – Signed Binary Proxy Execution: Mshta (T1218.005)
5. Execution – Command and Scripting Interpreter: PowerShell (T1059.001)
6. Execution – Signed Binary Proxy Execution: Regsvr32 (T1218.010)
7. Execution/Persistence – Scheduled Task/Job: Scheduled Task (T1053.005)
8. Execution/Defense Evasion – Command and Scripting Interpreter (T1064)

9. Execution – User Execution: Malicious Link (T1204.001)
10. Persistence – System Services: Service Execution (T1569.002)
11. Persistence – Create or Modify System Service: Windows Service (T1543.003)
12. Persistence – Office Application Startup (T1137)
13. Persistence – Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder (T1547.001)
14. Defense Evasion – Masquerading: Match Legitimate Name or Location (T1036.005)
15. Defense Evasion – Modify Registry (T1112)
16. Defense Evasion – NTFS File Attributes (T1096)
17. Defense Evasion – Obfuscated Files or Information (T1027)
18. Discovery – Network Service Scanning (T1046)
19. Command and Control – Ingress Tool Transfer (T1105)
20. Command and Control – Application Layer Protocol: Web Protocols (T1071.001)

0. Pick a technique to focus on from the above list
Initial Access – Phishing: Spearphishing Attachment (T1566.001)

1. What defensive options can you identify for dealing with the chosen technique?

- Email Filtering: Use security gateways to scan attachments in a sandbox and block known malicious file types.
- Macro Restrictions: Disable Office macros via Group Policy or limit them to digitally signed scripts from trusted sources.
- Endpoint Protection (EDR): Monitor for suspicious activity, such as Word or Excel launching command shells or PowerShell.
- User Training: Conduct regular phishing simulations to help employees recognize and report suspicious emails.
- Least Privilege: Restrict administrative rights to prevent malicious files from installing persistent backdoors.

2. Using either your own organization or a notional one, what are your organizations capabilities and constraints that may impact the identified defensive options?

Amazon has a world class security team and a huge budget, allowing for smart automation. However, their massive size (millions of workers) makes training difficult.

They also move very fast, meaning strict security rules might accidentally break important tools used in warehouses, slowing down deliveries.

3. Given your organization's capabilities and constraints, what are the tradeoffs for each of the defensive options?

Every choice has a downside. Strong filters might block real business emails by mistake. Blocking macros makes things safe but can stop employees from doing their jobs. Tracking every move keeps the network safe but can slow down older computers.

4. What are your final recommendations? Are they technical, policy, or risk acceptance?

- Technical: Use specific rules to block dangerous actions (like Word opening a command prompt) instead of blocking all macros.
- Policy: Remove Admin rights for most staff to stop malware from spreading.
- Risk Acceptance: Accept that some emails will always get through. Focus on fast response using automation to find and kill the threat the moment someone clicks.